



NIS2: Ihr Wegweiser zur Compliance.

Wie Sie Ihr Unternehmen geplant und rechtzeitig NIS2-konform machen können.

bechtle.com

Wie Sie Ihr Unternehmen geplant und rechtzeitig NIS2-konform machen können.



NIS2? Viele Organisationen sehen sich zum ersten Mal mit diesem Kürzel konfrontiert. Dabei handelt es sich um eine EU-Richtlinie zur Verbesserung der Cybersicherheit aus dem Jahr 2016 (NIS1), deren reformierte Fassung (NIS2) nun bis Oktober 2024 in deutsches Recht überführt werden muss.

Der Kreis der Organisationen, die diese Vorgaben beachten und umsetzen müssen, vergrößert sich dadurch deutlich. Insbesondere bisher nicht betroffene Organisationen aus neu festgelegten Sektoren und Branchen werden nun erstmals von NIS2 adressiert. Von ihnen verlangt die Richtlinie unter anderem, die Security-Prozesse und-Technologien auf ein umfassendes und standardisiertes Niveau zu erhöhen.

Um NIS2-Konformität zu erreichen, reicht es jedoch nicht aus, Produkte zu erwerben und zu installieren. Silolösungen und die Abdeckung von Teildisziplinen sind nicht zielführend und können sogar kontraproduktiv sein. Es geht vielmehr darum, den individuellen organisatorischen und technischen Handlungsbedarf als Managementaufgabe zu verstehen, Defizite zu identifizieren und mit den jeweils nötigen Werkzeugen, Methoden und Praktiken zu beheben.

NIS2 erfordert erstmalig eine ganzheitliche Betrachtung der Organisation, ihrer Prozesse und Technologien.

Wer von NIS2 betroffen ist.

Schätzungen zufolge werden allein in Deutschland rund 30.000 Organisationen und Einrichtungen von den Anforderun-

gen der NIS2-Richtlinie betroffen sein, die in folgende Kategorien unterteilt werden.

Zu den **wesentlichen** Einrichtungen zählen Unternehmen aus den Bereichen

- Energie
- Verkehr
- Bankwesen
- Finanzmärkte
- Gesundheitswesen
- Trinkwasser
- Abwasser
- Digitale Infrastruktur
- IT & Telekommunikation
- Öffentliche Verwaltung
- Weltraum

Zu den **wichtigen** Einrichtungen zählen Unternehmen aus den Bereichen

- Abfallwirtschaft
- Post- und Kurierdienste
- Lebensmittelproduktion, Verarbeitung und Vertrieb
- Produktion: Herstellung und Handel mit chemischen Stoffen
- Produktion: Herstellung und Verarbeitung von Medizinprodukten, Maschinen, Fahrzeugen sowie elektrischen und digitalen Geräten
- Anbieter digitaler Dienste (Suchmaschinen, Onlinemarktplätze)
- Forschung

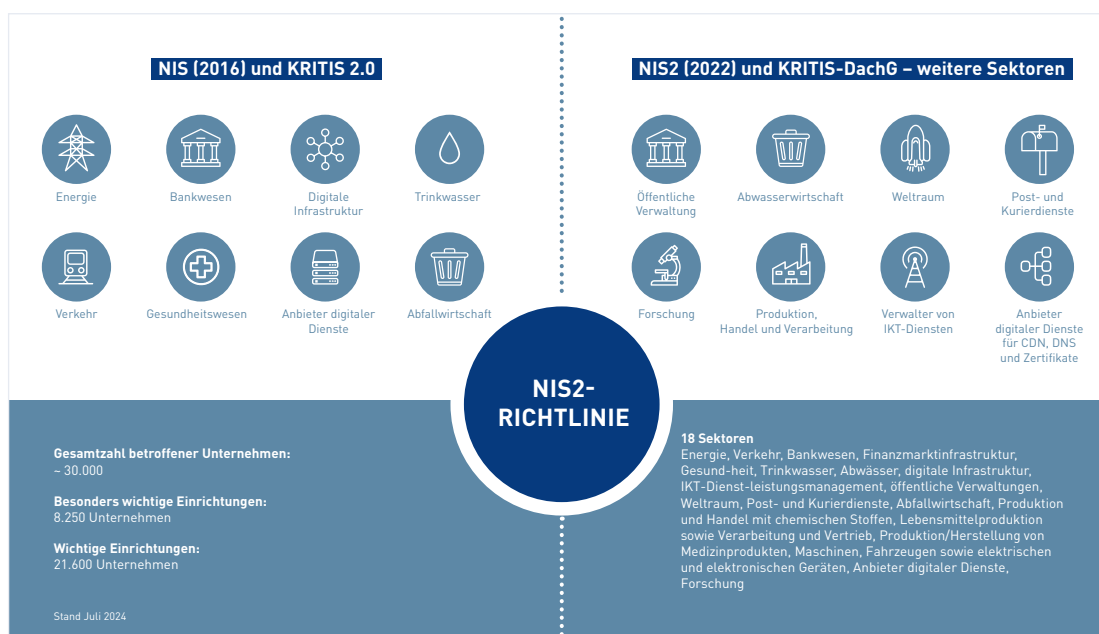


Abb. 1: Insgesamt sind 18 Sektoren von der NIS2-Richtlinie betroffen.

Ein weiteres Kriterium für die Einordnung ist die **Größe der Organisation**. Diese werden in zwei Größenkategorien eingeordnet:

Zu den **besonders wichtigen Einrichtungen** zählen solche, die in den entsprechend aufgeführten Sektoren tätig sind, mindestens 250 Mitarbeitende beschäftigen und einen Umsatz von mindestens 50 Millionen Euro und/oder eine Bilanzsumme von mindestens 43 Millionen Euro erzielen.

Zu den wichtigen **Einrichtungen** zählen solche aus beiden Bereichen, die zwischen 50 und 249 Mitarbeitende beschäftigen und einen Jahresumsatz zwischen zehn und 50 Millionen

Euro und/oder eine Bilanzsumme zwischen zehn und 43 Millionen Euro aufweisen.

Der Unterschied zwischen einer besonders wichtigen und einer wichtigen Einrichtung besteht vor allem in unterschiedlichen Meldepflichten und Sanktionsmöglichkeiten. Hinzu kommen Sonderfälle wie beispielsweise Anbieter qualifizierter Vertrauensdienste oder DNS-Diensteanbieter, die unabhängig von ihrer Größe von NIS2 betroffen sind.

Die bisherigen KRITIS-Unternehmen fallen alle in eine dritte Kategorie der sogenannten **Betreiber kritischer Anlagen**.

Betreiber kritischer Anlagen (KRITIS).

Für die Versorgung der Bevölkerung haben sie strengere Vorgaben zu erfüllen als Unternehmen der Kategorie besonders wichtigen Einrichtungen. Sie unterliegen zusätzlich den Anforderungen einer Neufas-

sung der KRITIS-Verordnung, die sich zurzeit als KRITIS-Dachgesetz ebenfalls noch in der Gesetzgebungsphase befindet und noch nicht veröffentlicht ist (Stand Juni 2024).

Betreiber kritischer Anlagen (KRITIS)	- I Schwellenwerte werden pro Anlage definiert - I Die Betreiber müssen mit KRITIS-Methodik die Betroffenheit einzelner Anlagen nach KRITIS-Verordnung festlegen - I Stringente Anforderungen, hohe Bußgelder, konkrete Haftung
Besonders wichtige Einrichtungen	- I Unternehmen ab 250 Mitarbeitern oder - I Unternehmen ab 50 Mio. EUR Umsatz und Bilanz ab 43 Mio. EUR - I Strenge Anforderungen, hohe Bußgelder
Wichtige Einrichtungen	- I Unternehmen ab 50 Mitarbeitern - I Unternehmen ab 10 Mio. EUR Umsatz und Bilanz ab 10 Mio. EUR - I Weniger strenge Anforderungen, niedrigere Bußgelder

Abb.2: Von NIS2 betroffene Organisationen werden in drei Kategorien eingeteilt.

Registrierungspflicht.

Der Gesetzgeber erwartet von den **wichtigen und besonders wichtigen Einrichtungen**, dass diese Organisationen eine Selbsteinschätzung durchführen, ob sie der NIS2-Richtlinie unterliegen. Wenn ja, müssen sie sich spätestens drei Monate nach Veröffentlichung der nationalen Umsetzung beim Bundesamt für Informationssicherheit (BSI) als betroffene Organisation registrieren.

Die genauen Details hierzu sind noch nicht veröffentlicht. Es ist jedoch zu erwarten, dass eine Frist bis Ende des ersten Quartals

2025 für eine Registrierung in einem Meldeportal des BSI gefordert wird.

Bei einer unklaren Selbsteinschätzung der Betroffenheit empfiehlt es sich, eine juristische Beratung durch einen IT-Fachanwalt oder eine IT-Fachanwältin einzuholen, um rechtlich belastbare Aussagen der Konsequenzen einer NIS2-Betroffenheit als Entscheidungsgrundlage zu erhalten.

Was eine NIS2-Betroffenheit für Ihre Organisation bedeutet.

Ist das Ergebnis der geforderten Selbsteinschätzung zur Betroffenheit positiv, muss nun in einem zweiten Schritt geprüft werden, welcher Handlungsbedarf für Ihre Organisation daraus entsteht. Die NIS2-Richtlinie und deren Umsetzung in nationale Gesetzgebung

verlangt die Etablierung von umfangreichen Managementmaßnahmen für die Risikobehandlung, die Informationssicherheit sowie für Notfall- und Cybersicherheitsprozesse. Sie müssen ganzheitlich innerhalb der betroffenen Organisationen umgesetzt werden.

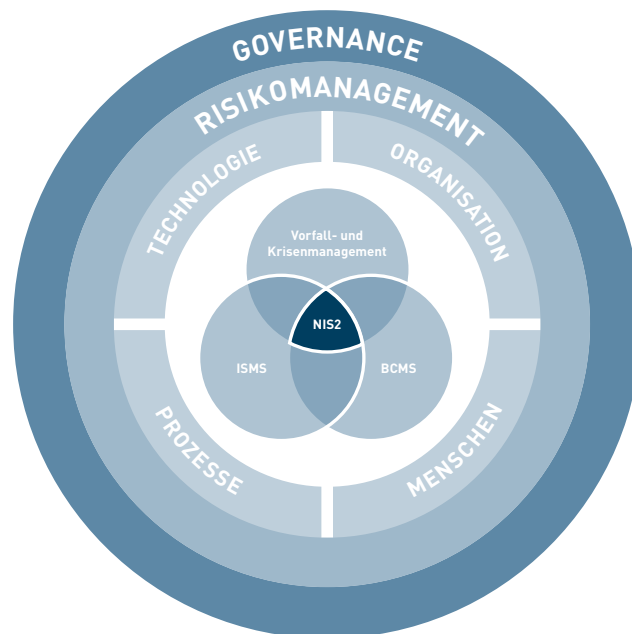


Abb.3: Nötige Managementmaßnahmen müssen ganzheitlich umgesetzt werden.

Der Handlungsbedarf orientiert sich daran, welche organisatorischen und technischen Maßnahmen bisher schon umgesetzt wurden. Folgende Anforderungen zum Themenkomplex Risikomanagement stellen NIS2 (Art.21) beziehungsweise die Neufassung des BSI-Gesetzes (BSIG, §30 und 31):

Risikomanagement und Informationssicherheit.

Gefordert ist die ganzheitliche und systematische Behandlung von Risiken (Identifikation bis Bewältigung) für den Betrieb und die Sicherheit der Werte des Unter-

nehmens. Dies kann durch die Etablierung von Managementsystemen für das Risikomanagement, die Informationssicherheit (ISMS) und Governance-Prozesse (GRC) gewährleistet werden.

Business Continuity Management.

Gefordert ist die Implementierung von Notfallmaßnahmen einschließlich eines Backup-Managements, Disaster-Recovery und eines Krisenmanagements, um die Geschäftsfortführung in allen Situationen sicherzustellen.

■ Sicherheit bei der Beschaffung und Entwicklung.

Es müssen Sicherheitsmaßnahmen für den Erwerb, die Entwicklung und die Wartung von IT-Systemen, Komponenten und Prozessen vorhanden sein. Gemäß der NIS2-Richtlinie ist es erforderlich, hierfür klare Sicherheitsanforderungen zu etablieren und durchgängig umzusetzen. Sie müssen den aktuellen technologischen Standards entsprechen und regelmäßige Risikobewertungen sowie das Management von Schwachstellen beinhalten.

■ Identitätsmanagement.

Gefordert werden unter anderem Konzepte und Lösungen zur Anwendung von Multi-Faktor-Authentifizierung und gesicherter Kommunikationsverbindungen. Die Grundlagen hierfür werden geschaffen durch die Etablierung von Systemen zur Identitätsverwaltung im Unternehmen.

■ Incident Management.

Gefragt sind Konzepte zur Bewältigung von Sicherheitsvorfällen. Für gravierende Störungen gelten zeitlich kritische Meldepflichten innerhalb von 24 Stunden.

■ Kryptografie.

Verlangt werden Konzepte und Verfahren für den Einsatz von Kryptografie und Verschlüsselung nach dem Stand der Technik sowie deren Anwendung in allen Kommunikationsverbindungen.

■ Personelle Sicherheit.

Sie beinhaltet Konzepte für die Zugriffskontrolle und das zentrale Management des Zugangsschutzes zu Anlagen und IT-Systemen, um den Missbrauch von

Zugängen durch Identitätsdiebstahl zu vermeiden.

■ Schulung und Awareness.

Gefordert ist die Durchführung von Schulungen im Bereich der Cybersicherheit. Es sind sicherheitsorientierte Denk- und Verhaltensweisen zu vermitteln, die Mitarbeitende verinnerlichen sollten, um zum Schutz gegen Cyberangriffe beizutragen.

■ Supply Chain.

Dies umfasst die Sicherheit der Lieferkette mit den vertraglichen Anforderungen mit Zulieferern und dienstleistenden Unternehmen. Organisationen müssen ihren Lieferanten und Dienstleistern, die Teil der Lieferkette sind, höhere Sicherheitsanforderungen auferlegen.

■ Wirksamkeitsprüfungen und Nachweisführung.

Gefragt sind Verfahren zur fortlaufenden Bewertung und Verbesserung der Wirksamkeit aller Maßnahmen im Bereich der Cybersicherheit und des Betriebs der Managementsysteme. Spezieller Fokus muss dabei auf die Nachweisbarkeit aller erforderlichen Maßnahmen durch angemessene Dokumentation gelegt werden.

Eine weitere Neuerung von NIS2 besteht in engmaschigeren Kontrollen durch die Aufsichtsbehörden sowie verschärften Sanktionsmechanismen. Dazu zählen wesentlich höhere Bußgelder ebenso wie ein deutlicher Hinweis auf die persönliche Haftung der Geschäftsführung.

Security ist und bleibt auch mit NIS2 Sache der Chefinnen und Chefs!

Wie Organisationen NIS2-Anforderungen mit Bechtle strukturiert und bedarfsgerecht angehen und umsetzen können.

Wir empfehlen Ihnen als Handlungsstrategie, mit der Durchführung eines NIS2-Compliance-Assessments zu beginnen. Ein solches Assessment ermittelt die erforderlichen Grundlagen für die Erstellung einer strategischen Roadmap für die Sicherheit, Zukunftsfähigkeit und Resilienz Ihrer Organisation.

derlichen Grundlagen für die Erstellung einer strategischen Roadmap für die Sicherheit, Zukunftsfähigkeit und Resilienz Ihrer Organisation.

Strategische Bedeutung.

Das Bechtle NIS2-Assessment ermöglicht es Organisationen, ihre Sicherheitsstrategie zielgerichtet zu formulieren, vorhandene Prozesse zu stärken und sich systematisch auf die dynamischen Herausforderungen der Cybersicherheit vorzubereiten. Es bietet eine strukturierte Herangehensweise, um Schwachstellen zu identifizieren, Sicherheitslücken zu schließen und präventive

Maßnahmen zu entwickeln, die das Risiko von Sicherheitsvorfällen minimieren. Dadurch wird nicht nur der Schutz kritischer, wesentlicher und wichtiger Infrastrukturen in Ihrer Organisation gewährleistet, sondern auch die Grundlage für das Vertrauen von Kunden und Geschäftspartnern in die digitale Zuverlässigkeit Ihrer Organisation gestärkt.

BECHTLE NIS2-ASSESSMENT Ablauf und Vorgehensweise

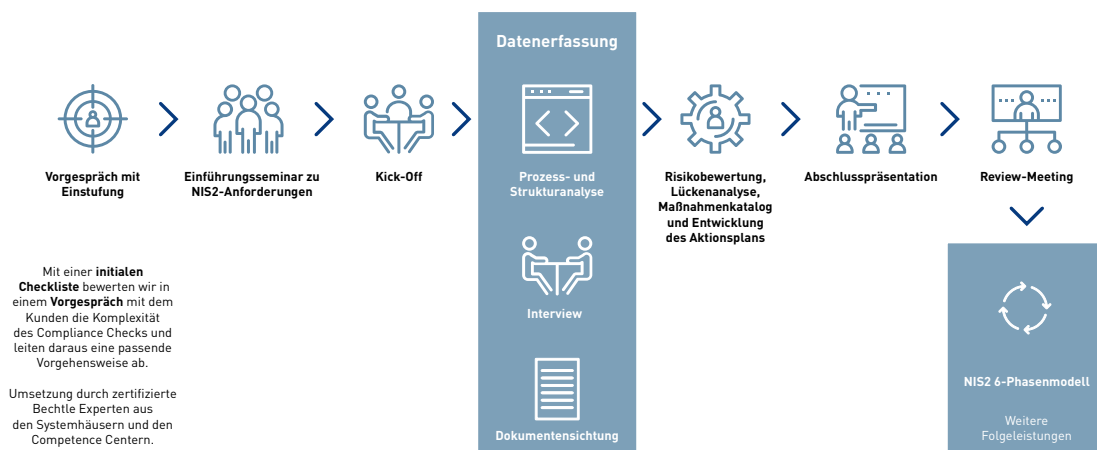


Abb. 4: Ein strukturiertes Vorgehen zeigt den Handlungsbedarf auf.

Vorgehensweise.

Zur Erfüllung der NIS2-Anforderungen und in Abhängigkeit vom Reifegrad Ihrer bereits vorhandenen Aufbau- und Ablauforganisation fassen wir die umzusetzenden

Maßnahmen aus den Erkenntnissen des NIS2-Assessments in den nachfolgenden **Themenclustern** zusammen, die in der Umsetzungsplanung berücksichtigt werden:

CLUSTER 1:

RISIKOMANAGEMENT, INFORMATIONSSICHERHEIT UND BUSINESS CONTINUITY.

(Organisatorische Themen ISMS, BCMS, Governance, Risk und Compliance)

- Risikomanagement und Informationssicherheit im Unternehmen
- BCMS und Krisenmanagement
- Erforderliche Managementsysteme hierfür
- Etablierung einer Meldekette für Sicherheitsvorfälle
- Stand der Technik etablieren
- Wissensmanagement und Nachweisfähigkeit
- Sicherheit der Lieferkette
- Beschaffung, Wartung und Entwicklung von Systemen

CLUSTER 2:

TECHNOLOGIEN UND KONZEPTE.

(Workplace und Perimeter Security)

- Rechte- und Technologiekonzepte
- Kryptografie und Stand der Technik etablieren
- ZeroTrust-Architektur



CLUSTER 3:

PRÄVENTION, DETEKTION UND REAKTION.

(Cybercrime und Defence)

- Incident Management (Erkennung und Behandlung von Zwischenfällen)
- Managed Security Services (SOC, SIEM, CSIRT und APT-Response-Dienstleistungen)

CLUSTER 4:

FAKTOR MENSCH UND SICHERHEITSKULTUR.

(Human Centric Security)

- Personelle Sicherheit
- Schulung und Awareness
- Identity Management und Governance
- Multifaktor-Authentifizierung

Umsetzungsplanung.

Für den Aufbau und die anschließende Nachverfolgung einer für Ihre Organisation maßgeschneiderten Unternehmensstrategie

zur Umsetzung der NIS2-Anforderungen gehen wir gemäß unserem Bechtle 6-Phasenmodell für das NIS2-Framework vor.

Im NIS2-Assessment wird der Ist-Stand zur NIS2-Konformität analysiert. Dieser bildet die Grundlage für die erfolgreiche Umsetzung der NIS2-Anforderungen.

Unser NIS2 6-Phasenmodell

Bechtle NIS2-Framework - Ganzheitliche Betrachtung.
Risikomanagement, Informationssicherheit & Business Continuity



Abb. 5: Strategisches Vorgehen mit dem 6-Phasenmodell von Bechtle.

Phase 1:

Wir ermitteln den Status quo Ihrer Organisation anhand des NIS2-Assessments.

Phase 2:

Wir entwerfen eine maßgeschneiderte Strategie, um den Anforderungen und den Vorgaben der NIS2-Richtlinie gerecht zu werden.

Phase 3:

Wir erarbeiten eine für Ihre Organisation, dem Schutzbedarf der Prozesse und Assets angemessene Zielarchitektur.

Phase 4:

Wir erstellen eine Maßnahmenplanung, die anhand der Risiken Ihrer Organisation priorisiert strukturiert wird.

Phase 5:

Der Veränderungsprozess in Ihrer Organisation beginnt und wird fortlaufend überwacht, um die Zielarchitektur zeitgerecht wie geplant erreichen zu können.

Phase 6:

Die umgesetzten Maßnahmen zur NIS2-Konformität werden in den Regelbetrieb überführt, fortlaufend verbessert und durch die Nachweisführung für die Aufsichtsbehörden erfüllt.

Mit Bechtle jetzt NIS2-Readiness erlangen.

Bechtle begleitet den gesamten Prozess zur NIS2-Konformität herstellerneutral und mit einem maßgeschneiderten organisatorischen und technischen Lösungsportfolio. Profitieren Sie von der langjährigen Erfahrung unserer Expert:innen und den Competence Centern zu den genannten NIS2-Themenbereichen.

Setzen Sie sich mit uns in Verbindung und erfahren Sie mehr über unsere Security-Services sowie viele weitere IT-Security-Dienstleistungen und -Lösungen.
nis2-compliance@bechtle.com



Ihr NIS2-Navigator: Meistern Sie die neue Richtlinie zur Cyber-Sicherheit.

Entdecken Sie die Welt von NIS2, ihr Leitaden zur neuen Richtlinie, die eine Vielzahl von Unternehmen betrifft. Wir haben für Sie die wichtigsten Informationen und Erkenntnisse zu NIS2 zusammengefasst, um Ihnen einen umfassenden Einblick in dieses wichtige Thema zu geben. Hinweis: Unser Informationsangebot wächst ständig. Im Laufe des Jahres fügen wir kontinuierlich neue Inhalte hinzu, die direkt hier veröffentlicht werden.

<https://www.bechtle.com/nis2>

Sie haben Fragen zu NIS2? nis2-compliance@bechtle.com

bechtle.com